

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-ISO-03

Understanding the SoA

A Practical Guide to the Statement of Applicability in ISO/IEC 27001:2022
TSEC Compliance Insights | ISO 27001 Series

Document ID:	GUIDE-ISO-03
Version:	2026 Edition
Effective Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

1. What Is the Statement of Applicability?

The Statement of Applicability (SoA) is one of the most important — and most misunderstood — documents in an ISO 27001 implementation. Required by Clause 6.1.3(d), the SoA is a formal record of which controls from Annex A the organization has determined are applicable, together with the justification for including or excluding each control, and the implementation status of applicable controls.

Think of the SoA as the bridge between your risk assessment and your control environment: the risk assessment tells you which risks you need to treat; the SoA documents which controls you've selected (including from Annex A) to treat them, and confirms that you've reviewed all 93 Annex A controls to ensure none were overlooked.

2. The Legal Requirement

ISO/IEC 27001:2022 Clause 6.1.3 requires the organization to: (a) select appropriate information security risk treatment options; (b) determine all controls necessary to implement the chosen risk treatment options; (c) compare the determined controls with those in Annex A and verify that no necessary controls have been omitted; and (d) produce a Statement of Applicability that contains the necessary controls, justification for inclusion or exclusion, whether they are implemented, and justification for exclusions.

Critically, the SoA must exist and must be current for ISO 27001 certification. Certification auditors will ask to see it at Stage 1, and will use it during Stage 2 to identify controls they want to verify are effectively implemented.

3. The Four Annex A Themes (ISO 27001:2022)

ISO/IEC 27001:2022 reorganized the Annex A control set from 114 controls in 14 domains (2013 version) into 93 controls in four thematic areas. Understanding these themes helps you navigate the SoA:

Theme	Controls	What It Covers
A.5 Organizational Controls	37 controls (5.1-5.37)	Policies, roles, asset management, access control governance, supplier relationships, incident management, business continuity, compliance
A.6 People Controls	8 controls (6.1-6.8)	Screening, terms of employment, training, disciplinary process, responsibilities after termination, remote working, reporting
A.7 Physical Controls	14 controls (7.1-7.14)	Physical perimeters, access controls, environmental protections, equipment security, clear desk/screen, secure disposal
A.8 Technological Controls	34 controls (8.1-8.34)	User access, privileged access, cryptography, vulnerability management, logging, monitoring, network security, secure development

4. How to Complete the SoA

Step 1: Establish Your Control Set Through Risk Treatment

Before completing the SoA, complete your risk assessment and risk treatment. For each identified risk you've decided to mitigate, determine which controls are necessary. These controls drive your SoA — you're not starting from Annex A and working backward, you're starting from your risks and working forward.

Step 2: Map Your Controls to Annex A

Compare the controls you've determined necessary against the Annex A list. For each Annex A control, determine whether it is applicable (included in your control set), and if so, document the justification (typically a risk reference, a legal/regulatory requirement, or a business necessity).

Step 3: Document Exclusions with Justification

For controls you're excluding, you must document a justification. Valid justifications include: the control addresses a risk that doesn't exist in your environment (e.g., 'A.8.25 Secure development lifecycle' is not applicable because all software development is outsourced to a vendor whose own ISO 27001 certification covers this control); or the control addresses a type of asset you don't have (e.g., a cloud-only organization may not have in-house physical server equipment).

Step 4: Record Implementation Status

For each applicable control, record whether it is: Implemented, Partially Implemented, Planned (with expected completion date), or Not Yet Implemented. This status information is valuable both for your internal tracking and for the Stage 1 auditor's readiness assessment.

5. Common SoA Mistakes

Mistake	Why It's a Problem	Better Approach
Marking all 93 controls as 'Applicable — Implemented' without genuine justification	Auditors can tell. They'll select controls to test in Stage 2 and find that 'implemented' controls have no evidence of operation	Be honest about implementation status. It's better to have some 'Partially Implemented' entries than to overclaim and fail testing
Excluding controls without documented justification	ISO 27001 requires justification for exclusions. Unexplained exclusions are a major nonconformity	For every exclusion, document clearly why the control is not applicable to your organization
Completing the SoA before the risk assessment	The SoA should flow from the risk assessment, not precede it. If controls are selected before risks are identified, the controls won't actually address the real risks	Complete the risk assessment and risk treatment first; the SoA is an output of that process
Not keeping the SoA current	The SoA must reflect the current state of the organization. An SoA that hasn't been updated since certification is a gap finding waiting to happen	Review and update the SoA at management review and whenever significant changes affect the ISMS scope or risk profile

6. The SoA in Customer and Auditor Conversations

Beyond its role in the certification process, the SoA is often requested by sophisticated customers during vendor due diligence. A well-maintained SoA demonstrates that your organization has thought systematically about which security controls are relevant to your environment, made risk-based decisions about implementation, and can explain and defend those decisions. It is a more mature and credible artifact than simply claiming 'we are ISO 27001 certified.'

7. Key Takeaways

- The SoA is mandatory for ISO 27001 certification and documents the rationale for each Annex A control's inclusion or exclusion
- It flows from the risk assessment — controls are selected to treat identified risks, then compared against Annex A
- Every exclusion must have a documented, defensible justification
- Implementation status in the SoA should be honest — overclaiming leads to audit failures
- The SoA must be kept current throughout the certification lifecycle, updated at management review and upon significant organizational changes

8. SoA Worked Examples: Inclusion and Exclusion Justifications

The following examples illustrate well-written justification statements for both inclusion and exclusion of Annex A controls in a typical cloud-native SaaS organization.

Control	Applicability	Justification
5.1 Policies for information security	Applicable — Implemented	Required to establish management direction for information security; implemented through the Information Security Policy, Access Control Policy, and other topic-specific policies listed in the ISMS Manual.
5.23 Information security for use of cloud services	Applicable — Implemented	Required: the organization's production environment is hosted entirely on cloud infrastructure (AWS); cloud security configuration, shared responsibility model understanding, and cloud provider due diligence are essential controls addressing risks R-003 and R-007.
7.11 Supporting utilities	Not Applicable	The organization does not own or directly manage physical data center facilities. Production infrastructure is hosted in a cloud provider's data centers under a carve-out approach; the cloud provider's responsibility for supporting utilities (power, cooling) is addressed in their own SOC 2 report and our vendor due diligence process.
8.4 Access to source code	Applicable — Implemented	The organization develops and maintains proprietary application software. Access to the source code repository is restricted to authorized engineering personnel and enforced through the identity provider with MFA. Source code access is subject to periodic access review.
8.25 Secure development life cycle	Applicable — Partially Implemented	The organization develops software in-house. SDLC security requirements including peer code review, security testing in CI/CD, and dependency scanning are implemented; formal secure coding training (8.28) is in progress — expected to be completed by Q3 2026.
8.30 Outsourced development	Not Applicable — No outsourced development at this time	All software development is performed by the organization's internal engineering team. If outsourced development is engaged in the future, this determination will be revisited and this control will be made applicable.

9. Maintaining the SoA Through Organizational Change

Organizational change is the most common cause of an SoA becoming outdated. The following events should trigger a review and update of the SoA:

- Introduction of a new system, cloud service, or application that handles information within the ISMS scope — may trigger applicability of previously excluded technological controls
- A new development team or the decision to bring previously outsourced development in-house — triggers applicability of the secure development lifecycle controls (8.25-8.31)
- Opening a new office or physical facility — triggers review of physical controls (A.7) that may not previously have been applicable
- Onboarding of a new major supplier or subprocessor — may trigger applicability of supply chain controls (5.19-5.22)
- A significant security incident revealing that a control previously assessed as not applicable was in fact needed — triggers immediate SoA review

10. The SoA and Customer Due Diligence

Enterprise customers and procurement teams with genuine security sophistication will sometimes request your SoA as part of vendor due diligence, either in addition to or instead of (or alongside) your ISO 27001 certificate. When sharing the SoA externally, consider:

- Sharing the SoA under a Non-Disclosure Agreement — it reveals detail about your control environment that may be sensitive
- Preparing a summary version that shows applicability determinations but omits detailed justifications that could reveal security architecture details
- Being prepared to discuss exclusions: a customer asking why 8.11 (Data masking) is marked Not Applicable deserves a clear, honest answer
- Using the SoA conversation as an opportunity to demonstrate the maturity of your risk-based approach — an organization that can confidently explain each applicability decision is more credible than one that simply shows a certificate